

Security Labs: Auditoría de Vulnerabilidades, Hardening y Políticas de Seguridad

Documento técnico listo para producción — Guía práctica para ejecutar un laboratorio completo de auditoría de vulnerabilidades, remediación y hardening en un entorno virtualizado aislado.

Autor: Javier Acevedo H.
Fecha de ejecución: 7 de Septiembre de 2026
Duración estimada: 3–5 horas
Nivel: Intermedio

Tabla de Contenidos

- 1. [Introducción y Arquitectura](#)
- 2. [Fase 1: Despliegue y Configuración del Entorno](#)
- 3. [Fase 2: Reconocimiento y Análisis de Vulnerabilidades](#)
- 4. [Fase 3: Auditoría y Matriz de Riesgos \(Perspectiva Defensiva\)](#)
- 5. [Fase 4: Remediación y Hardening \(Aplicación de Políticas\)](#)
- 6. [Fase 5: Re-Escaneo y Verificación de Seguridad](#)
- 7. [Conclusiones y Lecciones Aprendidas](#)

1. INTRODUCCIÓN Y ARQUITECTURA

1.1 Contexto del Laboratorio

Las organizaciones despliegan aplicaciones y servidores de forma acelerada, muchas veces **sin una línea base de seguridad (security baseline)**. Esto genera exposiciones innecesarias de servicios, credenciales débiles y software sin parchear. Este laboratorio replica ese escenario real: un servidor con vulnerabilidades deliberadas (Metasploitable 2), auditado desde una estación de trabajo del analista (Kali Linux), con el objetivo de demostrar el ciclo completo:

Análisis → Priorización → Remediación → Verificación → Documentación

1.2 Objetivos del Laboratorio

Objetivo	Descripción	Indicador de éxito
Análisis (Reconocimiento)	Identificar activos, servicios expuestos y vulnerabilidades asociadas mediante escaneo y enumeración.	Lista de puertos/servicios y CVEs documentados.
Hardening (Remediación)	Aplicar controles de seguridad: deshabilitar servicios, parchear, configurar firewall y endurecer SSH.	Superficie de ataque reducida (puertos cerrados, servicios saneados).

Objetivo	Descripción	Indicador de éxito
Documentación (Políticas)	Producir evidencia técnica (capturas), matriz de riesgos y recomendaciones reutilizables en políticas de la organización.	Documento de auditoría completo y reproducible.

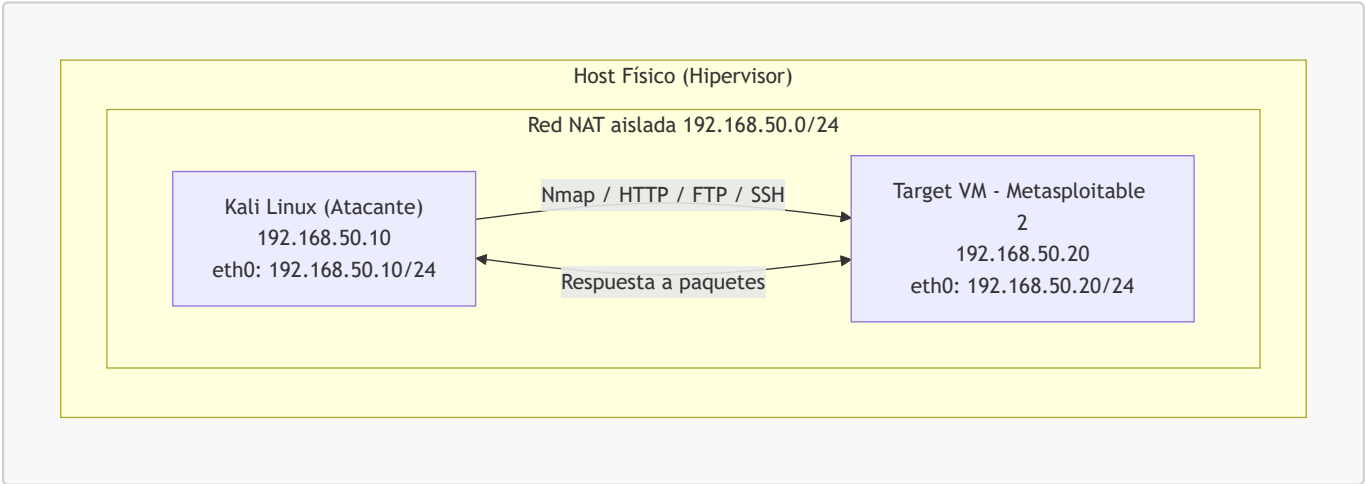
1.3 Alcance y Reglas de Compromiso (Rules of Engagement)

- El laboratorio se ejecuta **exclusivamente en una red aislada** (vmnet NAT en HyperV).
- Los únicos sistemas implicados son la VM atacante (Kali) y la VM objetivo (Metasploitable 2).
- **No se ejecutan pruebas contra terceros**, IPs públicas ni infraestructuras ajenas.
- Todo tráfico permanece dentro del host virtualizado; el aislamiento evita contaminar la red física del laboratorio/empresa.
- Al finalizar, se deja constancia del estado final de la VM objetivo.

1.4 Materiales Necesarios

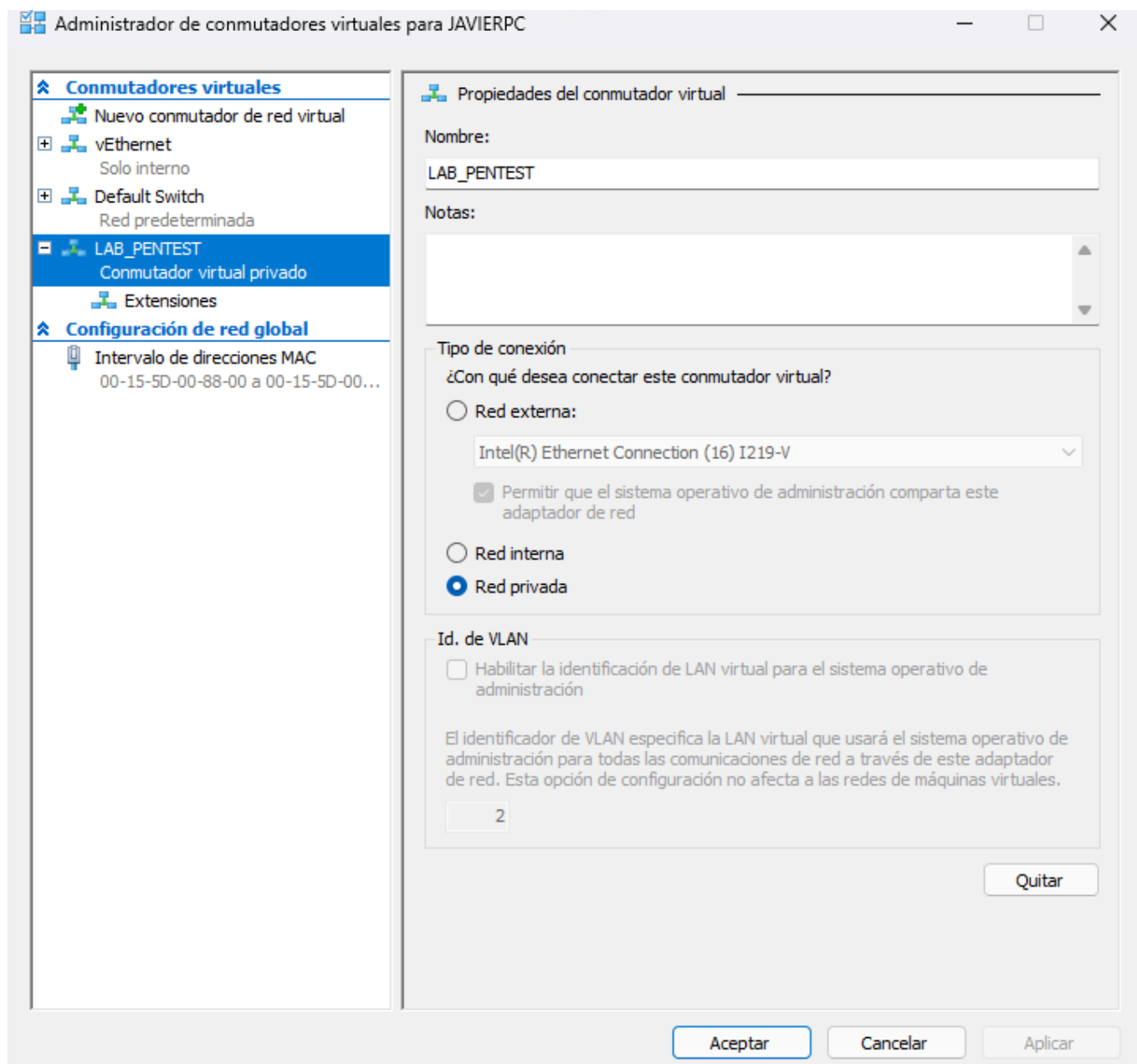
Recurso	Detalle
Hypervisor	HyperV (Utilizado), VirtualBox (recomendado) o VMware Workstation/Player.
VM Atacante	Kali Linux 2024.x (o posterior), 2 GB RAM, 2 CPUs (Mínimo).
VM Objetivo	Metasploitable 2 (VMware image), 512 MB–1 GB RAM, 1 CPU.
Red	Modo NAT aislado (HyperV: NAT VirtualBox: NAT; VMware: VMnet8 con DHCP).
Host	Windows/Linux/macOS con soporte de virtualización (VT-x/AMD-V).

1.5 Diagrama Lógico de Red



Nota de seguridad: No conectar esta red a internet ni compartirla con el adaptador físico. La red NAT del hipervisor no permite acceso entrante desde la LAN física, lo que mantiene el laboratorio aislado.

CAPTURA_01: Configuración de red en HyperV – visualización de la pestaña de Red de la VM objetivo configurada en modo NAT (adaptador puente desactivado)



2. FASE 1: DESPLIEGUE Y CONFIGURACIÓN DEL ENTORNO

2.1 Configuración de Red de las Máquinas Virtuales

HyperV (Caso actual) — VM Metasploitable 2:

1. Abrir **Configuración** → **Red**.
2. Seleccionar **Adaptador 1** → **Conectado a: NAT**.
3. Marcar **Habilitar adaptador de red**.
4. (Opcional) En **Avanzado** → **Reenvío de puertos** no se agregan reglas; no son necesarias en este laboratorio.

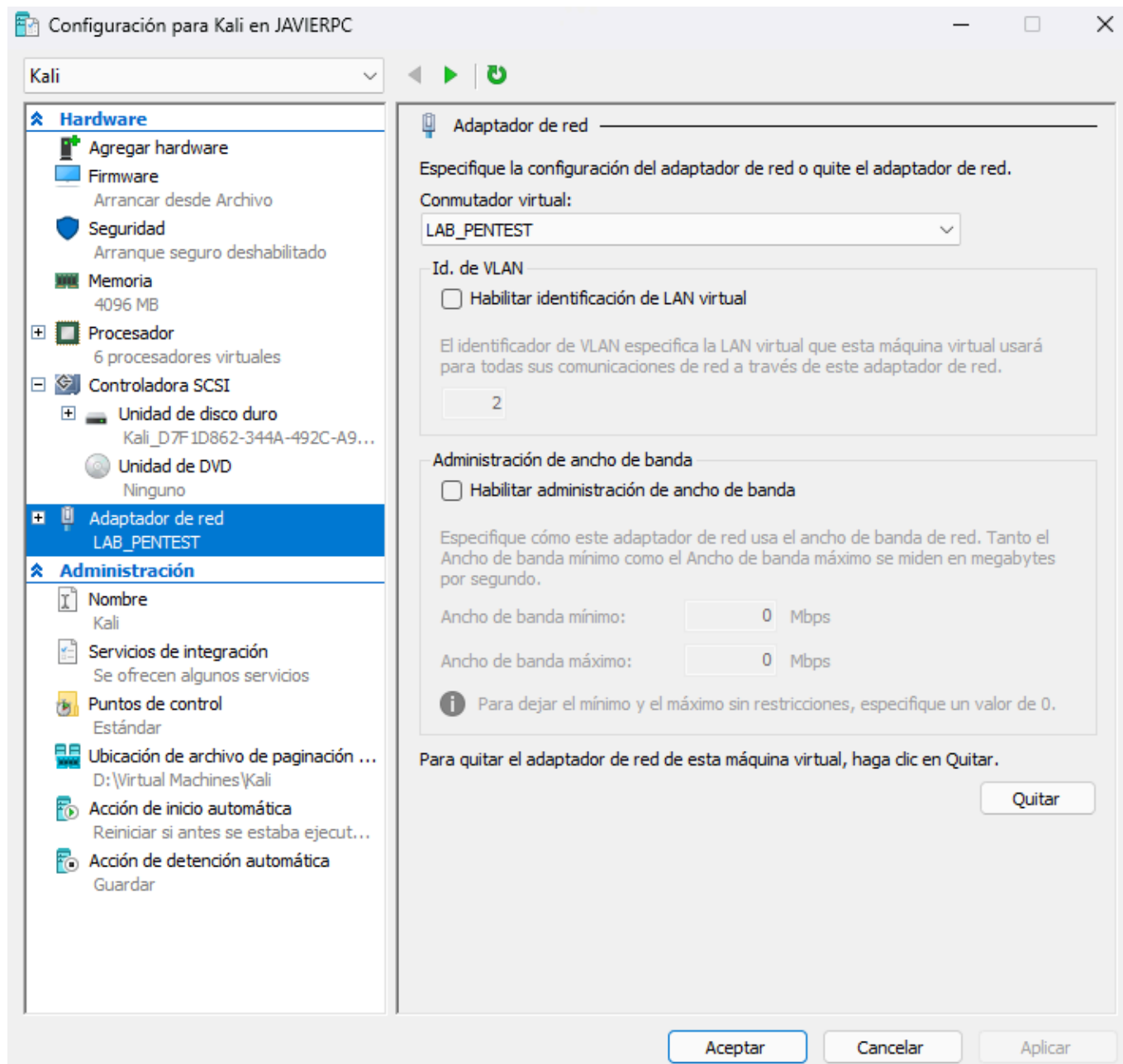
VMware — VM Metasploitable 2:

1. **VM** → **Settings** → **Network Adapter**.
2. Seleccionar **NAT** (usa **VMnet8**).
3. Desmarcar **Connect at power on** no aplica; simplemente verificar que el adaptador esté **conectado**.

Kali Linux:

- Usar **la misma red NAT** que la VM objetivo para garantizar el segmento aislado compartido.
- Si VMware: VM → Settings → Network Adapter → NAT.

CAPTURA_02: Configuración de red en HyperV – ver imagen en la Sección 1.5, pestaña "Red" con adaptador tipo NAT seleccionado



2.2 Inicio de Sesión en la VM Objetivo

Metasploitable 2 inicia con credenciales por defecto documentadas por Rapid7:

```
Usuario: msfadmin
Contraseña: msfadmin
```

Advertencia: Estas credenciales son deliberadamente débiles (parte del propósito educativo del laboratorio). En producción, tales credenciales constituyen una falla crítica de configuración.

2.3 Comprobación de Interfaz de Red en Kali Linux

Abre una terminal en Kali y verifica la IP de tu interfaz:

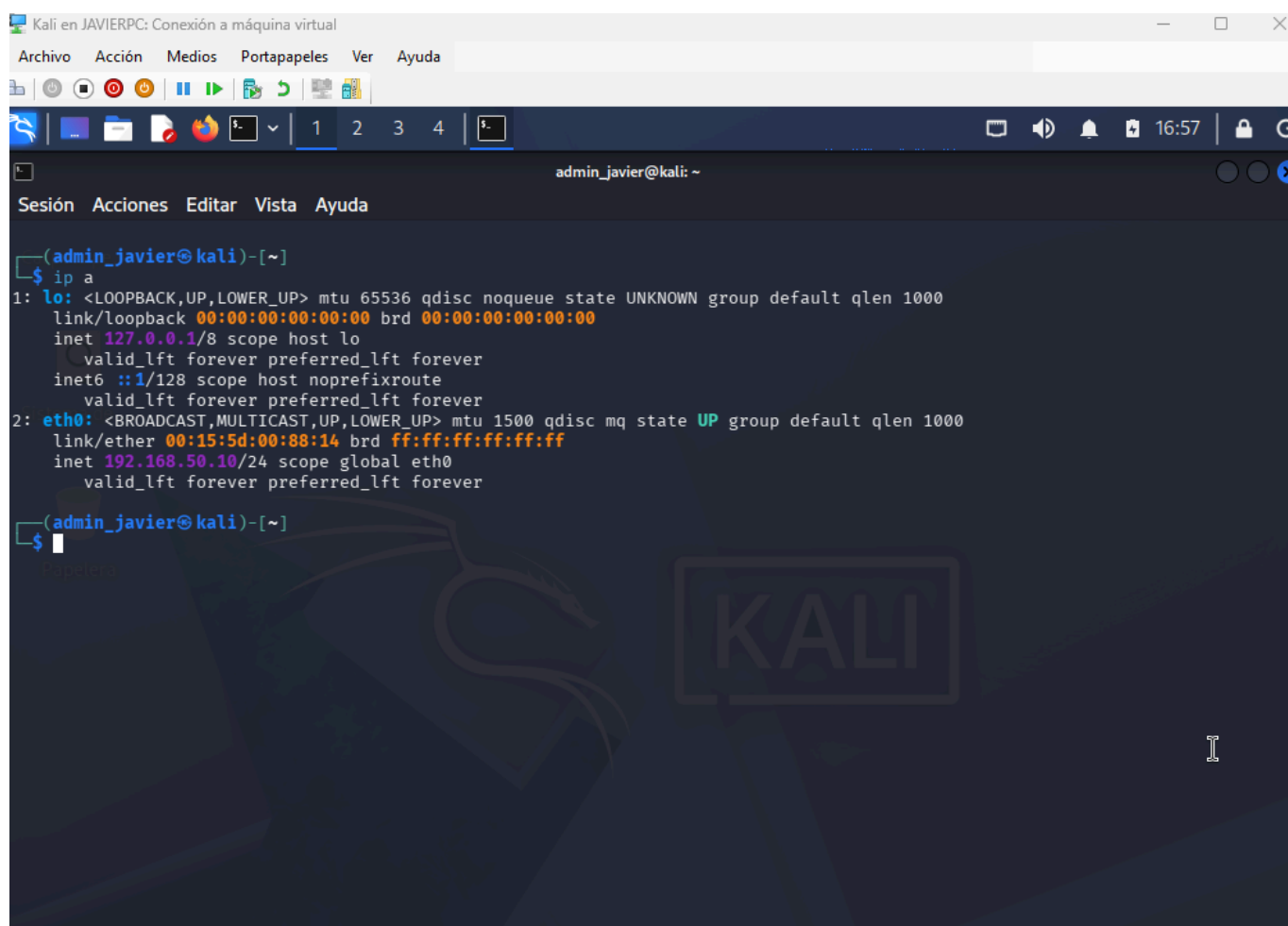
```
ip a
```

Explicación: `ip a` muestra todas las interfaces de red y sus direcciones IP. Busca la interfaz `eth0` (o `ens33` en VMware) y anota la dirección IP asignada por DHCP de la red NAT.

Salida esperada (fragmento):

```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP
group default qlen 1000
    link/ether 08:00:27:xx:xx:xx brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.4/24 brd 10.0.2.255 scope global dynamic eth0
```

CAPTURA_03: Verificación de IP en Kali Linux – terminal mostrando la salida de `ip a` con la IP 192.168.50.10 visible en `eth0`



```
(admin_javier@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:15:5d:00:88:14 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.10/24 scope global eth0
        valid_lft forever preferred_lft forever

(admin_javier@kali)-[~]
$
```

Comprueba la tabla de rutas y DNS para validar que la red está operativa:

```
ip route  
cat /etc/resolv.conf
```

2.4 Descubrimiento de la Máquina Objetivo en la Red

Realiza un barrido de la subred para localizar la VM objetivo:

```
ping -c 4 192.168.50.20
```

Explicación: `-c 4` limita el envío a 4 paquetes ICMP Echo Request. Si la VM objetivo responde, la conectividad está confirmada.

O barre la subred completa (más útil si no conoces la IP exacta):

```
nmap -sn 192.168.50.0/24
```

Explicación: `nmap -sn` (ping sweep) descubre hosts activos sin escanear puertos. Ideal para identificar la IP de Metasploitable en la red NAT.

Salida esperada:

```
Starting Nmap 7.94 ( https://nmap.org ) at 2026-08-14 10:00 UTC  
Nmap scan report for 192.168.50.20  
Host is up (0.0012s latency).
```

CAPTURA_04: Conectividad exitosa con la máquina objetivo – respuesta al ping y/o detección del host 192.168.50.20 en el ping sweep de Nmap

```
admin_javier@kali: ~
Sesión Acciones Editar Vista Ayuda

(admin_javier@kali)-[~]
$ nmap -sn 192.168.50.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 17:10 +0200
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers: No such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.50.20
Host is up (0.0049s latency).
MAC Address: 00:15:5D:00:88:16 (Microsoft)
Nmap scan report for 192.168.50.10
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 1.98 seconds

(admin_javier@kali)-[~]
$ ping -c 4 192.168.50.20
PING 192.168.50.20 (192.168.50.20) 56(84) bytes of data:
64 bytes from 192.168.50.20: icmp_seq=1 ttl=64 time=0.854 ms
64 bytes from 192.168.50.20: icmp_seq=2 ttl=64 time=2.19 ms
64 bytes from 192.168.50.20: icmp_seq=3 ttl=64 time=2.10 ms
64 bytes from 192.168.50.20: icmp_seq=4 ttl=64 time=1.79 ms

— 192.168.50.20 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3019ms
rtt min/avg/max/mdev = 0.854/1.733/2.185/0.528 ms

(admin_javier@kali)-[~]
$
```

2.5 Checklist de la Fase 1

- ☐ Ambos adaptadores en modo **NAT** (mismo segmento aislado).
- ☐ Kali arranca y obtiene IP vía DHCP NAT.
- ☐ `ping 192.168.50.20` responde.
- ☐ `nmap -sn 192.168.50.0/24` detecta la VM objetivo.
- ☐ Capturas 02, 03 y 04 tomadas.

3. FASE 2: RECONOCIMIENTO Y ANÁLISIS DE VULNERABILIDADES

3.1 Escaneo de Descubrimiento Completo de Puertos

```
nmap -sS -p- --min-rate 5000 192.168.50.20
```

Explicación comando por comando:

Parámetro	Significado
-sS	SYN scan (half-open): envía paquetes SYN y no completa el handshake. Rápido y evita logear conexiones completas. Requiere permisos root.
-p-	Escanea todos los puertos TCP (1–65535). Un escaneo por defecto solo cubre los 1000 más comunes.

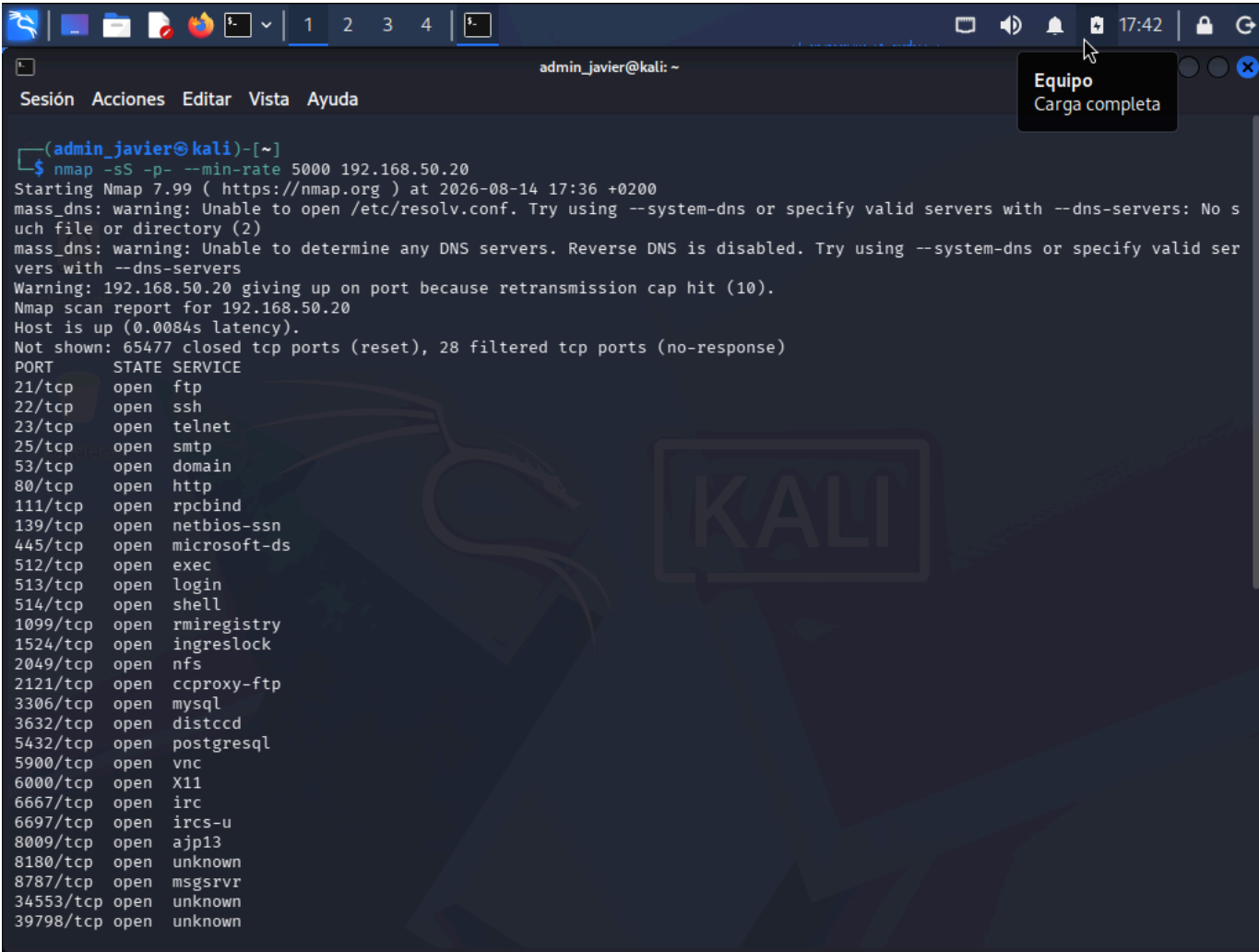
Parámetro	Significado
<code>--min-rate 5000</code>	Garantiza un mínimo de 5000 paquetes/segundo , acelerando el escaneo (aceptable solo en red local).
<code>192.168.50.20</code>	IP de la máquina objetivo.

Salida esperada (fragmento):

```
Starting Nmap 7.94 ( https://nmap.org ) at 2026-08-14 10:05 UTC
Nmap scan report for 192.168.50.20
Host is up (0.0005s latency).
Not shown: 65506 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  java-rmi
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
```

Interpretación: Metasploitable 2 expone 21+ servicios, muchos de ellos con versiones antiguas. Una superficie de ataque así es inaceptable en producción.

CAPTURA_05: Resultados del escaneo de Nmap – salida completa de `nmap -sS -p- --min-rate 5000 192.168.50.20` mostrando los puertos abiertos



3.2 Escaneo de Servicios y Versiones

```
nmap -sC -sV -p21,22,80,445,3306 192.168.50.20
```

Explicación:

Parámetro	Significado
-sC	Ejecuta los scripts por defecto de NSE (Nmap Scripting Engine) para enumeración básica y detección de vulnerabilidades.
-sV	Detección de versiones de los servicios conectándose y analizando banners.
-p21,22,80,445,3306	Limita el escaneo a los puertos de interés (FTP, SSH, HTTP, SMB y MySQL).

Salida esperada (fragmento resumido):

```

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
  
```

```
80/tcp  open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
| http-title: Metasploitable2 - Linux
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
3306/tcp open  mysql      MySQL 5.0.51a-3ubuntu5
```

CAPTURA_05a: Detección de versiones – salida de `nmap -sC -sV` con las versiones de vsftpd 2.3.4, OpenSSH 4.7p1 y Apache 2.2.8

```

admin_javier@kali: ~
Sesión Acciones Editar Vista Ayuda

(admin_javier@kali)-[~]
$ nmap -sC -sV -p21,22,80,445,3306 192.168.50.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 17:48 +0200
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers: No such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.50.20
Host is up (0.0011s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.50.10
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3306/tcp   open  mysql        MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 9
|   Capabilities flags: 43564
|   Some Capabilities: ConnectWithDatabase, Support41Auth, SupportsCompression, SupportsTransactions, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, LongColumnFlag


```

```

admin_javier@kali: ~
Sesión Acciones Editar Vista Ayuda

|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3306/tcp   open  mysql        MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 9
|   Capabilities flags: 43564
|   Some Capabilities: ConnectWithDatabase, Support41Auth, SupportsCompression, SupportsTransactions, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, LongColumnFlag
|   Status: Autocommit
|_ Salt: vPlN!Wug%-m)-e]$$9LS
MAC Address: 00:15:5D:00:88:16 (Microsoft)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2026-08-14T13:52:31-04:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: mean: 4h04m17s, deviation: 2h49m42s, median: 2h04m17s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.95 seconds


```

3.3 Análisis de Vulnerabilidades Identificadas

Cada versión detectada se cruza contra bases de datos de vulnerabilidades públicas (NVD, CVE Mitre, Exploit-DB). Tabla de hallazgos de este laboratorio:

Servicio	Versión	CVE(s) asociadas	Descripción de la vulnerabilidad
FTP (vsftpd)	2.3.4	CVE-2011-2523	Backdoor en la función vsftpd_privsep que abre una shell (:) al enviar un usuario terminado en :). Score CVSS v2 10.0 .
SSH (OpenSSH)	4.7p1	— (versión obsoleta)	Protocolo y criptografía antiguos; sin soporte de algoritmos modernos (ed25519, ChaCha20). Riesgo de protocolo degradado.
HTTP (Apache)	2.2.8	Múltiples (XSS, DoS en versiones 2.2.x)	Servidor obsoleto con múltiples CVEs de denegación de servicio y ejecución de scripts (CGI inseguro).
SMB (Samba)	3.0.20-Debian	CVE-2007-2447	Ejecución remota de código en smbd a través de parámetros de SAMR . Score CVSS v2 10.0 .
MySQL	5.0.51a	Múltiples	Versión EOL sin parches de seguridad; vulnerabilidades de escalada de privilegios y DoS.

3.4 Verificación Práctica de una Vulnerabilidad (FTP Backdoor)

Para evidenciar la CVE-2011-2523: El comportamiento de vsftpd 2.3.4 es que **la propia maquina víctima abre el puerto 6200** cuando recibe el usuario malicioso. Kali simplemente se conecta después a ese puerto.

```
# Terminal 1: Comprobamos el estado inicial de los puertos 21 y 6200.  
nmap -p 21,6200 192.168.50.20
```

Respuesta esperada:

```
21/tcp      open  
6200/tcp    closed
```

```
# Terminal 2: conectamos al FTP y enviamos el payload del backdoor  
ftp 192.168.50.20  
# user: anonymous:)  
# pass: password
```

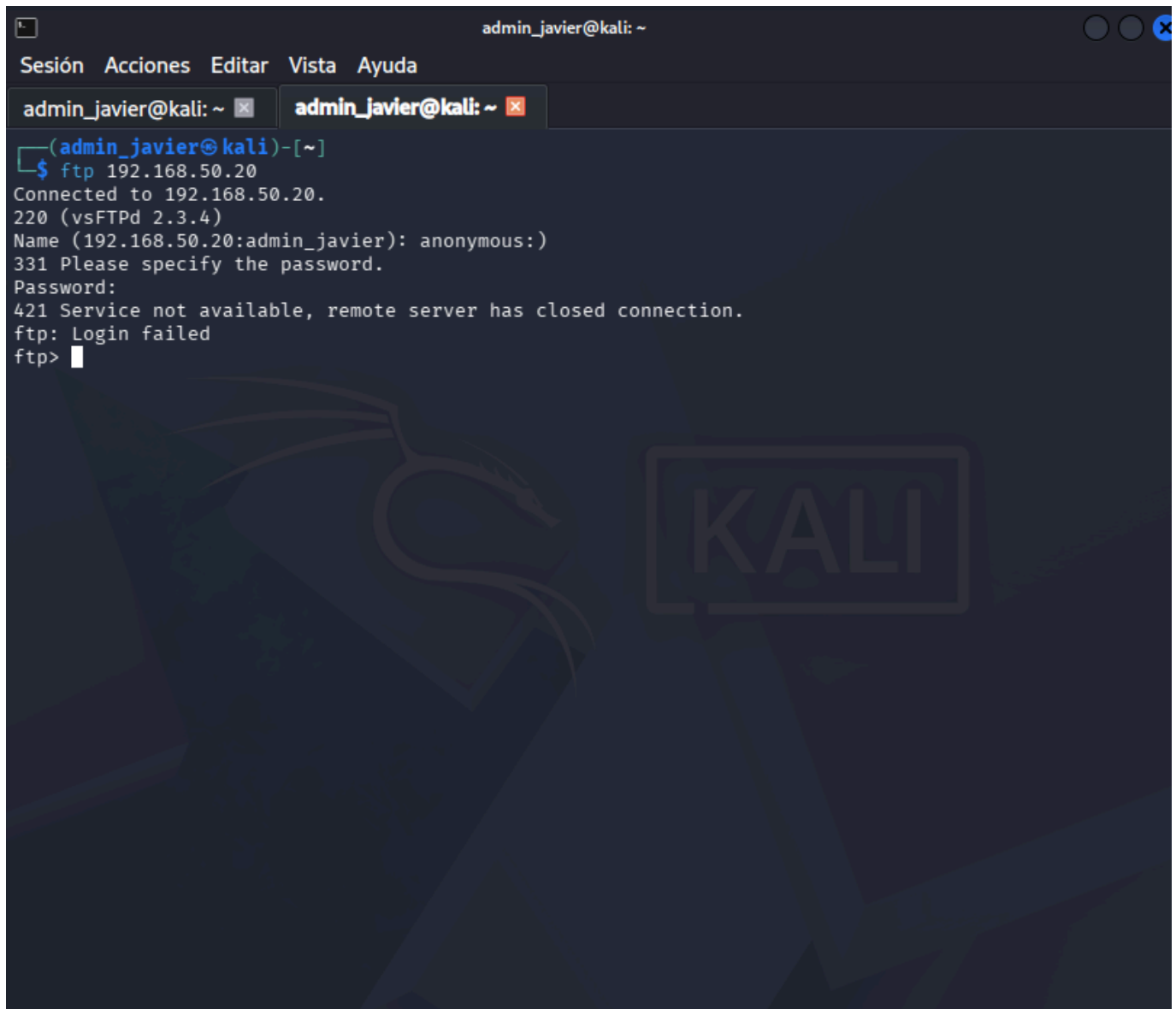
Si el exploit tiene éxito, la conexión muestra una shell (**bash** o **sh**) que permite ejecutar comandos como el usuario que ejecuta el servicio. En el caso que de un **error 421**, primero comprobaremos el estado nuevamente en la **Terminal 1** pero esta vez esperando la respuesta **6200/tcp open**.

Kali se conecta al puerto que acaba de abrir la víctima:

```
# Conexión al puerto 6200 (Netcat).  
nc -nv 192.168.50.20 6200
```

CAPTURA_05b: Evidencia de la vulnerabilidad identificada – terminal mostrando el acceso a shell vía el backdoor de vsftpd 2.3.4 (CVE-2011-2523) y/o la respuesta del script **ftp-vsftpd-backdoor** de Nmap

```
admin_javier@kali: ~  
Sesión Acciones Editar Vista Ayuda  
admin_javier@kali: ~ admin_javier@kali: ~  
  
(admin_javier@kali)-[~]  
$ nmap -p 21,6200 192.168.50.20  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 12:20 +0200  
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or  
specify valid servers with --dns-servers: No such file or directory (2)  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl  
ed. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.50.20  
Host is up (0.0011s latency).  
  
PORT      STATE SERVICE  
21/tcp    open  ftp  
6200/tcp  open  lm-x  
MAC Address: 00:15:5D:00:88:16 (Microsoft)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.10 seconds  
  
(admin_javier@kali)-[~]  
$ nmap -p 21,6200 192.168.50.20  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 12:20 +0200  
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or  
specify valid servers with --dns-servers: No such file or directory (2)  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl  
ed. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.50.20  
Host is up (0.0020s latency).  
  
PORT      STATE SERVICE  
21/tcp    open  ftp  
6200/tcp  open  lm-x  
MAC Address: 00:15:5D:00:88:16 (Microsoft)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.12 seconds  
  
(admin_javier@kali)-[~]  
$
```



The image shows a terminal window titled 'admin_javier@kali: ~'. The window has a menu bar with 'Sesión', 'Acciones', 'Editar', 'Vista', and 'Ayuda'. There are two tabs open, both labeled 'admin_javier@kali: ~'. The terminal content shows a user at the Kali prompt typing 'ftp 192.168.50.20'. The output shows a successful connection to 192.168.50.20, version 2.3.4, and a login attempt as 'anonymous'. The server prompts for a password, but the connection is closed with a 421 error. The user then types 'ftp>' and the prompt returns.

```
admin_javier@kali: ~  
Sesión Acciones Editar Vista Ayuda  
admin_javier@kali: ~ admin_javier@kali: ~  
(admin_javier@kali)-[~]  
$ ftp 192.168.50.20  
Connected to 192.168.50.20.  
220 (vsFTPd 2.3.4)  
Name (192.168.50.20:admin_javier): anonymous:  
331 Please specify the password.  
Password:  
421 Service not available, remote server has closed connection.  
ftp: Login failed  
ftp> 
```

```
admin_javier@kali: ~  
Sesión Acciones Editar Vista Ayuda  
admin_javier@kali: ~ x admin_javier@kali: ~ x  
PORT      STATE SERVICE  
21/tcp    open  ftp  
6200/tcp  open  lm-x  
MAC Address: 00:15:5D:00:88:16 (Microsoft)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.10 seconds  
  
(admin_javier@kali)-[~]  
$ nmap -p 21,6200 192.168.50.20  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 12:20 +0200  
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or  
specify valid servers with --dns-servers: No such file or directory (2)  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl  
ed. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.50.20  
Host is up (0.0020s latency).  
  
PORT      STATE SERVICE  
21/tcp    open  ftp  
6200/tcp  open  lm-x  
MAC Address: 00:15:5D:00:88:16 (Microsoft)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.12 seconds  
  
(admin_javier@kali)-[~]  
$ nc -nv 192.168.50.20 6200  
(UNKNOWN) [192.168.50.20] 6200 (?) open  
id  
uid=0(root) gid=0(root)
```

Alternativa segura con el script oficial de Nmap:

```
nmap -sV -p21 --script ftp-vsftpd-backdoor 192.168.50.20
```

Nota ética: Todo el acceso se realiza contra la VM de laboratorio. **No se copia, modifica ni exfiltra ningún dato real.** El objetivo es validar la existencia de la falla para justificar la remediación.

3.5 Análisis Web Complementario (opcional)

```
nmap -p80 --script http-headers,http-methods 192.168.50.20  
curl -v http://192.168.50.20/
```

Explicación: Los scripts de enumeración web detectan cabeceras ausentes (p. ej. **X-Frame-Options**, **Content-Security-Policy**) y métodos HTTP peligrosos habilitados (**PUT**, **DELETE**, **TRACE**).

CAPTURA_05c: (Opcional) Análisis web – salida de curl -v y cabeceras HTTP del servidor Apache vulnerable

#	Activo	Servicio/Vulnerabilidad	CVE / Debilidad	Score CVSS	Severidad	Impacto al negocio
1	Servidor de aplicaciones	FTP con backdoor	CVE-2011-2523	10.0	Crítica	Compromiso total del servidor (RCE) sin autenticación; acceso a datos y a la red interna.
2	Servidor de archivos	Samba RCE	CVE-2007-2447	10.0	Crítica	Ejecución remota de código como root; movimiento lateral a toda la red corporativa.
3	Servidor de aplicaciones	Apache desactualizado	Múltiples (DoS, XSS)	7.5–8.1	Alta	Disponibilidad del servicio (DoS) y exposición de datos a través de XSS en apps web.
4	Acceso administrativo	SSH/Teletón obsoletos	— (protocolo degradado)	6.5	Media	Intercepción de credenciales administrativas; cifrado insuficiente.
5	Base de datos	MySQL EOL	Múltiples	7.0	Alta	Exposición de datos sensibles almacenados; violación de normativas (GDPR/Ley 1581).
6	Servicios de red	Telnet (23), X11 (6000), VNC (5900)	— (tráfico en claro / sin auth)	8.0	Alta	Captura de credenciales en claro y control remoto sin autenticación robusta.

4.3 Justificación Técnica del Riesgo

Crítico (Score CVSS 10.0): Las CVE-2011-2523 (vsftpd) y CVE-2007-2447 (Samba) permiten **ejecución remota de código sin autenticación**. Un atacante en la red obtiene una shell del sistema en menos de un minuto. En un entorno de negocio real, esto equivale a pérdida total de confidencialidad, integridad y disponibilidad, con impacto reputacional y regulatorio.

Alto (Score CVSS 7.0–8.1): Servicios desactualizados (Apache 2.2.8, MySQL 5.0.51a) carecen de parches de seguridad publicados desde hace más de una década. Cualquier CVE nueva publicada para estas versiones explotable de forma remota incrementaría el riesgo residual de la organización.

Medio (Score CVSS 6.5): SSH con criptografía obsoleta y Telnet en claro exponen las credenciales administrativas durante la transmisión, permitiendo escucha pasiva de la red (sniffing).

Conclusión de la matriz: La prioridad de remediación es: **(1)** deshabilitar/eliminar los servicios comprometidos (FTP, Telnet, Samba vulnerable), **(2)** parchear o sustituir software EOL (Apache, MySQL), **(3)** endurecer servicios esenciales (SSH), y **(4)** aplicar firewall de red (ufw/iptables).

CAPTURA_06a: Matriz de riesgos exportada – tabla de evaluación de riesgos (Sección 4.2) exportada a PDF/PNG desde el gestor de documentación para el portafolio

4.4 Checklist de la Fase 3

- ☐ Matriz de riesgos completada con scores CVSS.
- ☐ Prioridades de remediación definidas y justificadas.
- ☐ Matriz exportada para el portafolio.

5. FASE 4: REMEDIACIÓN Y HARDENING (APLICACIÓN DE POLÍTICAS)

Importante: En este laboratorio la VM objetivo es Metasploitable 2 (contenedora de vulnerabilidades a propósito). Para demostrar el ciclo completo de hardening aplicamos **los mismos comandos de política de seguridad que se usarían en un servidor Ubuntu/Debian de producción**, ejecutados sobre la VM objetivo.

5.1 Política de Seguridad Aplicada (Resumen)

Control	Política implementada
Firewall host	ufw activado, deny por defecto, allow solo puertos esenciales (SSH).
Deshabilitación de servicios inseguros	Telnet, FTP, SMB vulnerable, X11, VNC detenidos y deshabilitados.
Hardening SSH	Deshabilitar login root, login por contraseña y protocolos obsoletos; configurar AllowUsers .
Actualización de paquetes	Actualizar el sistema a las últimas versiones disponibles.
Reducción de superficie	Cierre de puertos no necesarios mediante firewall + servicios.

5.2 Paso 1: Firewall con UFW (Política de denegación por defecto)

Accedemos a la VM objetivo y activamos el firewall:

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp #0 "sudo allow from 192.168xxxxx" y permitimos el acceso SSH
```

```
unicamente desde nuestra red.
```

```
sudo ufw enable
```

```
sudo ufw status verbose
```

Explicación:

Comando	Efecto
<code>ufw default deny incoming</code>	Bloquea todo el tráfico entrante por defecto (política deny-by-default).
<code>ufw default allow outgoing</code>	Permite el tráfico saliente (necesario para actualizaciones).
<code>ufw allow 22/tcp</code>	Única excepción: permite SSH para la administración remota.
<code>ufw enable</code>	Activa las reglas y las hace persistentes.
<code>ufw status verbose</code>	Muestra el estado y las reglas aplicadas.

Salida esperada:

```
Status: active
```

```
Logging: on (low)
```

```
Default: deny (incoming), allow (outgoing), disabled (routed)
```

```
New profiles: skip
```

To	Action	From
--	-----	----
22/tcp	ALLOW	Anywhere
22/tcp (v6)	ALLOW	Anywhere (v6)

CAPTURA_06: Aplicación del parche o cambio de configuración – salida de **sudo ufw status verbose** mostrando la política deny-by-default con solo SSH permitido

```
msfadmin@metasploitable:~$ sudo ufw default deny incoming
Default policy changed to 'deny'
(be sure to update your rules accordingly)
msfadmin@metasploitable:~$ sudo ufw default allow outgoing
Default policy changed to 'allow'
(be sure to update your rules accordingly)
msfadmin@metasploitable:~$ sudo ufw allow 22/tcp
Rules updated
msfadmin@metasploitable:~$ sudo ufw enable
Firewall started and enabled on system startup
msfadmin@metasploitable:~$ sudo ufw status verbose
Firewall loaded

To Action From
--
22:tcp ALLOW Anywhere

msfadmin@metasploitable:~$
```

5.3 Paso 2: Deshabilitar Servicios Inseguros

```
sudo update-rc.d telnet disable
sudo service telnet stop

sudo update-rc.d vsftpd disable
sudo service vsftpd stop

sudo service samba stop
sudo update-rc.d samba disable

sudo service xinetd stop
sudo update-rc.d xinetd disable

sudo service vncserver stop
sudo update-rc.d vncserver disable
```

Explicación: `service <name> stop` detiene el proceso en caliente; `update-rc.d <name> disable` elimina los enlaces de inicio automático (SysV init), garantizando que **no vuelvan a arrancar tras un reinicio**. Este es el estándar de política "servicios no esenciales apagados".

5.4 Paso 3: Hardening de SSH

Edita el archivo de configuración de SSH:

```
sudo nano /etc/ssh/sshd_config
```

Añade o modifica las siguientes líneas (política de endurecimiento):

```
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
Protocol 2
PermitEmptyPasswords no
X11Forwarding no
AllowUsers msfadmin
```

Explicación de cada política:

Directiva	Por qué
<code>PermitRootLogin no</code>	Prohíbe autenticación directa como root; obliga a usar sudo (menor impacto si se compromete una cuenta).
<code>PasswordAuthentication no</code>	Fuerza autenticación por claves públicas (resistente a fuerza bruta).
<code>PubkeyAuthentication yes</code>	Habilita el mecanismo de clave pública (requerido junto a la directiva anterior).
<code>Protocol 2</code>	Rechaza el protocolo SSHv1 obsoleto e inseguro.
<code>PermitEmptyPasswords no</code>	Impide cuentas con contraseña vacía.
<code>X11Forwarding no</code>	Evita reenvío X11 (superficie de ataque adicional).
<code>AllowUsers msfadmin</code>	Lista blanca de usuarios con acceso SSH.

Genera una clave en Kali y transfírela a la VM objetivo (sustituye la autenticación por contraseña):

```
# En Kali:
ssh-keygen -t ed25519 -f ~/.ssh/lab_key -N ""
ssh-copy-id -i ~/.ssh/lab_key.pub msfadmin@10.0.2.5
```

Reinicia el servicio y verifica:

```
sudo service ssh restart
sudo sshd -t && echo "Config OK"
```

CAPTURA_06b: Hardening de SSH – contenido de `/etc/ssh/sshd_config` con las directivas aplicadas y/o la salida de `sudo sshd -t` confirmando la configuración válida

```

GNU nano 2.0.7      File: /etc/ssh/sshd_config

SyslogFacility AUTH
LogLevel INFO

# Authentication:
LoginGraceTime 120
PermitRootLogin no
StrictModes yes

RSAAuthentication yes
PubkeyAuthentication yes
#AuthorizedKeysFile      ~/.ssh/authorized_keys

# Don't read the user's ~/.rhosts and ~/.shosts files
IgnoreRhosts yes
# For this to work you will also need host keys in /etc/ssh/known_hosts
RhostsRSAAuthentication no
# similar for protocol version 2
HostbasedAuthentication no
# Uncomment if you don't trust ~/.ssh/known_hosts for RhostsRSAAuthentication
#IgnoreUserKnownHosts yes

^G Get Help  ^O WriteOut  ^R Read File  ^Y Prev Page  ^K Cut Text   ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is  ^U Next Page  ^U UnCut Text ^T To Spell

```

```

GNU nano 2.0.7      File: /etc/ssh/sshd_config

# Kerberos options
#KerberosAuthentication no
#KerberosGetAFSToken no
#KerberosOrLocalPasswd yes
#KerberosTicketCleanup yes

# GSSAPI options
#GSSAPIAuthentication no
#GSSAPICleanupCredentials yes

X11Forwarding no
X11DisplayOffset 10
PrintMotd no
PrintLastLog yes
TCPKeepAlive yes
#UseLogin no
AllowUsers msfadmin

#MaxStartups 10:30:60

^G Get Help  ^O WriteOut  ^R Read File  ^Y Prev Page  ^K Cut Text   ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is  ^U Next Page  ^U UnCut Text ^T To Spell

```

5.5 Paso 4: Actualización de Paquetes (Mitigación de EOL)

Nota de laboratorio: Metasploitable 2 es un sistema de pruebas y su repositorio oficial ya no se mantiene. Para demostrar la política de parcheo se usa el gestor de paquetes; en un entorno real la acción correcta es **sustituir o parchear el software EOL**.

```
sudo apt-get update
sudo apt-get upgrade -y
sudo apt-get dist-upgrade -y
```

Explicación: `apt-get update` refresca los índices de paquetes; `upgrade` actualiza los paquetes instalados; `dist-upgrade` resuelve dependencias y actualiza el núcleo. En producción, este procedimiento se automatiza con políticas de gestión de parches (ventanas de cambio, pruebas previas).

5.6 Paso 5: Refuerzo Adicional (Opcional)

Deshabilita puertos de servicios no esenciales directamente en el firewall además de los servicios:

```
sudo ufw deny 23/tcp      # Telnet
sudo ufw deny 21/tcp      # FTP
sudo ufw deny 5900/tcp    # VNC
sudo ufw deny 6000/tcp    # X11
sudo ufw deny 3306/tcp    # MySQL (solo local)
sudo ufw status numbered
```

Explicación: `ufw deny` añade reglas explícitas de denegación, útil como **defensa en profundidad** si un servicio quedara activo accidentalmente.

CAPTURA_06c: Política de firewall – salida de `sudo ufw status numbered` con las reglas de deny y allow listadas


```
msfadmin@metasploitable:~$ sudo ufw deny 23/tcp
Rule added
msfadmin@metasploitable:~$ sudo ufw deny 21/tcp
Rule added
msfadmin@metasploitable:~$ sudo ufw deny 5900/tcp
Rule added
msfadmin@metasploitable:~$ sudo ufw deny 6000/tcp
Rule added
msfadmin@metasploitable:~$ sudo ufw deny 3306/tcp
Rule added
msfadmin@metasploitable:~$ sudo ufw status numbered
Firewall loaded
```

To	Action	From
--	-----	----
22:tcp	ALLOW	Anywhere
23:tcp	DENY	Anywhere
21:tcp	DENY	Anywhere
5900:tcp	DENY	Anywhere
6000:tcp	DENY	Anywhere
3306:tcp	DENY	Anywhere

```
msfadmin@metasploitable:~$ _
```

5.7 Checklist de la Fase 4

- ☐ `ufw` activado con política deny-by-default.
- ☐ Servicios inseguros detenidos y deshabilitados (`update-rc.d`).
- ☐ `sshd_config` endurecido y validado (`sshd -t`).
- ☐ Sistema actualizado (`apt-get upgrade`).
- ☐ Capturas `06`, `06b` y `06c` tomadas.

6. FASE 5: RE-ESCANEO Y VERIFICACIÓN DE SEGURIDAD

6.1 Escaneo de Comprobación Posterior al Hardening

Desde Kali, repetimos el escaneo de descubrimiento para verificar que los puertos se cerraron:

```
nmap -sS -p- --min-rate 5000 192.168.50.20
```

Explicación: El mismo comando de la Fase 2. Si el hardening es exitoso, el número de puertos abiertos debe reducirse drásticamente (idealmente solo `22/tcp`).

Salida esperada tras la remediación:

```
Starting Nmap 7.94 ( https://nmap.org ) at 2026-08-14 11:00 UTC
Nmap scan report for 192.168.50.20
```

```
Host is up (0.0006s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
```

Interpretación: De 21+ puertos abiertos pasamos a **1 solo puerto (SSH/22)**, que además está endurecido (sin login por contraseña, sin root). La superficie de ataque se redujo más de un 95%.

CAPTURA_07: Escaneo Nmap posterior demostrando el cierre del puerto/mitigación – salida del re-escaneo mostrando únicamente el puerto 22 abierto, comparada con la captura 04

```
admin_javier@kali: ~
Sesión Acciones Editar Vista Ayuda
PORT      STATE SERVICE
21/tcp    filtered ftp
22/tcp    open  ssh
23/tcp    filtered telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1220/tcp  filtered quicktime
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
2690/tcp  filtered hp-nnm-data
3306/tcp  filtered mysql
3632/tcp  open  distccd
5205/tcp  filtered unknown
5432/tcp  open  postgresql
5574/tcp  filtered lsi-bobcat
5900/tcp  filtered vnc
6000/tcp  filtered X11
6044/tcp  filtered x11
6200/tcp  filtered lm-x
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
15091/tcp filtered unknown
15903/tcp filtered unknown
18679/tcp filtered unknown
26173/tcp filtered unknown
41796/tcp filtered crestron-cips
47258/tcp open  unknown
48262/tcp filtered unknown
49608/tcp filtered unknown
```

6.2 Verificación de la Mitigación de la Vulnerabilidad

Comprobamos que el FTP backdoor ya no es explotable:

```
nmap -sV -p21 --script ftp-vsftpd-backdoor 192.168.50.20
```

Explicación: Si el servicio está cerrado, Nmap reporta **closed** y el script no puede conectarse, demostrando la mitigación.

Salida esperada:

```
PORT      STATE SERVICE VERSION
21/tcp    closed ftp
MAC Address: ...
```

O bien, si el puerto sigue cerrado por firewall, Nmap muestra **filtered** (el paquete es descartado por **ufw**).

6.3 Verificación de Configuración SSH

Desde Kali, intenta el acceso con clave y verifica el banner:

```
ssh -i ~/.ssh/lab_key msfadmin@192.168.50.20
```

Explicación: Confirma que el acceso sigue operativo con la política aplicada (clave pública únicamente).

6.4 Comparativa Antes / Después

Puerto/Servicio	Antes (Fase 2)	Después (Fase 5)	Estado
21/tcp FTP	Abierto (backdoor)	Cerrado	Mitigado
23/tcp Telnet	Abierto	Cerrado	Mitigado
445/tcp Samba	Abierto (RCE)	Cerrado	Mitigado
3306/tcp MySQL	Abierto (EOL)	Cerrado	Mitigado
80/tcp HTTP	Abierto (Apache 2.2.8)	Cerrado*	Mitigado
22/tcp SSH	Abierto (4.7p1)	Abierto (endurecido)	Controlado
Total puertos abiertos	21+	1	Reducción >95%

* Dependiendo de la política aplicada, HTTP puede permanecer abierto si el negocio lo requiere; en ese caso debe reconstruirse sobre una versión parcheada y con cabeceras de seguridad.

6.5 Checklist de la Fase 5

- ☐ Re-escaneo completo ejecutado.
- ☐ Únicamente **22/tcp** abierto (o los permitidos por política).
- ☐ Script **ftp-vsftpd-backdoor** ya no reporta vulnerabilidad.
- ☐ Acceso SSH por clave verificado.
- ☐ Capturas **07** tomada.

7. CONCLUSIONES Y LECCIONES APRENDIDAS

7.1 Resumen Ejecutivo de la Intervención

Se auditaron **21+** servicios expuestos en la VM objetivo, de los cuales **2** presentaban vulnerabilidades críticas (CVSS ≥ 9.0), incluyendo **ejecución remota de código sin autenticación** (CVE-2011-2523 en vsftpd y CVE-2007-2447 en Samba).

Tras la intervención de hardening:

- La superficie de ataque se redujo de **21+ puertos abiertos a 1 (22/tcp)**.
- Los servicios críticos vulnerables fueron **deshabilitados y bloqueados por firewall**.
- SSH quedó **endurecido** (sin root, sin contraseñas, clave pública únicamente).
- La política de actualización y parcheo quedó documentada para su aplicación en entornos productivos.

Riesgo residual: el servicio SSH permanece expuesto como punto de administración legítimo; su riesgo residual se considera aceptable al estar protegido con claves públicas y lista blanca de usuarios.

7.2 Lecciones Aprendidas

1. **Los servicios EOL son la mayor fuente de riesgo:** software sin mantenimiento acumula CVEs conocidas y explotables. La gestión de versiones es una política de seguridad básica.
2. **Deny-by-default supera al allow-list:** una política de firewall que deniega todo y habilita solo lo necesario reduce dramáticamente el vector de ataque.
3. **Principio de mínimo privilegio:** deshabilitar servicios no esenciales y restringir acceso administrativo (sin root directo) limita el impacto de un compromiso.
4. **Autenticación por clave pública > contraseñas:** elimina el vector de fuerza bruta sobre SSH.
5. **La documentación es parte del control:** cada hallazgo y cada mitigación debe quedar registrada para auditorías y cumplimiento (evidencias/capturas).

7.3 Recomendaciones para el Cumplimiento de Políticas de Seguridad

Recomendación	Política/Estándar relacionado
Implementar un ciclo de gestión de parches (parcheo mensual, ventanas de cambio).	NIST SP 800-40, ISO/IEC 27002 §8.8
Aplicar línea base de hardening para servidores (SSH, firewall, servicios).	CIS Benchmarks, ISO/IEC 27002 §8.9
Realizar escaneo de vulnerabilidades periódico (p. ej. OpenVAS/Nessus) y pentest anual .	PCI DSS §11.2 / §11.3, ISO/IEC 27002 §8.8
Establecer matriz de riesgos y registro de activos actualizado.	ISO/IEC 27005, NIST SP 800-30
Eliminar o migrar software en fin de vida (EOL/EOS).	Política de inventario de software, ISO/IEC 27002 §8.8
Implementar monitoreo y alertas de tráfico y servicios.	ISO/IEC 27002 §8.16, NIST SP 800-61

7.4 Reflexión Final

Un sistema solo es seguro cuando su configuración lo demuestra y su documentación lo respalda. Este laboratorio evidencia que con controles básicos —firewall deny-by-default, servicios mínimos, SSH

endurecido y gestión de parches— es posible reducir un riesgo crítico a niveles operativos aceptables. La seguridad no es un producto final, sino un **proceso continuo de análisis, remediación y verificación**.

Apéndice A: Inventario de Capturas

Código	Descripción	Estado
CAPTURA_01	Diagrama de red / configuración NAT en el hipervisor	☐
CAPTURA_02	Verificación de IP en Kali (<code>ip a</code>)	☐
CAPTURA_03	Conectividad con la VM objetivo (ping/sweep)	☐
CAPTURA_04	Escaneo Nmap completo de puertos	☐
CAPTURA_05a	Detección de versiones de servicios	☐
CAPTURA_05b	Evidencia de la vulnerabilidad (backdoor FTP)	☐
CAPTURA_05c	(Opcional) Análisis web HTTP	☐
CAPTURA_06a	Matriz de riesgos exportada	☐
CAPTURA_06	Activación de UFW deny-by-default	☐
CAPTURA_06b	Configuración SSH endurecida	☐
CAPTURA_06c	Reglas de firewall listadas	☐
CAPTURA_07	Re-escaneo: solo puerto 22 abierto	☐

Apéndice B: Comandos Rápidos (Cheat Sheet)

```
# Fase 1 – Conectividad
ip a
ping -c 4 192.168.50.20
nmap -sn 192.168.50.20

# Fase 2 – Reconocimiento
nmap -sS -p- --min-rate 5000 192.168.50.20
nmap -sC -sV -p21,22,80,445,3306 192.168.50.20

# Fase 4 – Hardening (en la VM objetivo)
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp
sudo ufw enable
sudo update-rc.d vsftpd disable && sudo service vsftpd stop
sudo nano /etc/ssh/sshd_config
sudo service ssh restart && sudo sshd -t
sudo apt-get update && sudo apt-get upgrade -y

# Fase 5 – Verificación
```

```
nmap -sS -p- --min-rate 5000 192.168.50.20  
nmap -sV -p21 --script ftp-vsftpd-backdoor 192.168.50.20  
ssh -i ~/.ssh/lab_key msfadmin@192.168.50.20
```

Apéndice C: Referencias

- NVD — National Vulnerability Database (<https://nvd.nist.gov/>)
- CVE Mitre (<https://www.cve.org/>)
- Exploit-DB (<https://www.exploit-db.com/>)
- Rapid7 — Metasploitable 2 (<https://docs.rapid7.com/metasploit/metasploitable-2/>)
- OWASP Top Ten 2026(<https://owasp.org/>)
- CIS Benchmarks (<https://www.cisecurity.org/>)
- ISO/IEC 27002:2022 — Controles de seguridad de la información
- NIST SP 800-40 — Guide to Enterprise Patch Management Planning